An ninh mạng máy tính - Thực hành 05

1. Hướng dẫn brute force/dictionary attack bằng THC Hydra:

- Sinh viên xem hướng dẫn sử dụng THC Hydra để brute force form tại:

https://infinitelogins.com/2020/02/22/how-to-brute-force-websites-using-hydra/

- Hướng dẫn giải bài tập cộng điểm bằng THC Hydra:

  + Phương pháp tạo dictionary?

  + Ý nghĩa tham số trong THC Hydra:

```
Syntax: hydra [[[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE [-T TASKS]]
E] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-SOuvVd46] [service://server[:PORT][/OPT]]

Options:
  -R        restore a previous aborted/crashed session
  -S        perform an SSL connect
  -s PORT   if the service is on a different default port, define it here
  -l LOGIN or -L FILE  login with LOGIN name, or load several logins from FILE
  -p PASS  or -P FILE  try password PASS, or load several passwords from FILE
  -x MIN:MAX:CHARSET  password bruteforce generation, type "-x -h" to get help
  -e nsr    try "n" null password, "s" login as pass and/or "r" reversed login
  -u        loop around users, not passwords (effective! implied with -x)
  -C FILE   colon separated "login:pass" format, instead of -L/-P options
  -M FILE   list of servers to attack, one entry per line, ':' to specify port
  -o FILE   write found login/password pairs to FILE instead of stdout
  -f / -F   exit when a login/pass pair is found (-M: -f per host, -F global)
  -t TASKS  run TASKS number of connects in parallel (per host, default: 16)
  -w / -W TIME  waittime for responses (32) / between connects per thread (0)
  -4 / -6   use IPv4 (default) / IPv6 addresses (put always in [] also in -M)
  -v / -V / -d  verbose mode / show login+pass for each attempt / debug mode
  -O        use old SSL v2 and v3
  -q        do not print messages about connection errors
  -U        service module usage details
  server    the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
  service   the service to crack (see below for supported protocols)
  OPT       some service modules support additional input (-U for module help)

Supported services: asterisk cisco cisco-enable cvs firebird ftp ftps http[s]-{head|get|post} http[s]-{get|post}-form
roxy-urlenum icq imap[s] irc ldap2[s] ldap3[-{cram|digest}md5][s] mssql mysql nntp oracle-listener oracle-sid pcanywhe
postgres rdp redis rexec rlogin rsh rtsp s7-300 sip smb smtp[s] smtp-enum snmp socks5 ssh sshkey svn teamspeak telnet[
pp
```

  + Lệnh hydra: **hydra -L userlist.txt -P passwordlist.txt IPSERVER http-post-form "/index.php:email_signin=^USER^&password_signin=^PASS^&login=:S=User Profile"**

  + Cần lưu ý tham số -t (tasks number of connects in parallel) có khả năng ảnh hưởng đến số lượng password tìm được.

2. Giải pháp phòng chống tấn công brute force / dictionary:

- Ép buộc người dùng sử dụng "**mật khẩu an toàn**".

- Thay đổi URL đăng nhập (chỉ áp dụng trong số ít trường hợp).

- Sử dụng Firewall hoặc các công cụ hỗ trợ Firewall (ví dụ Fail2Ban) trên server để chặn IP khi số lượng request **vượt ngưỡng**. Tuy nhiên phương pháp này không khắc phục triệt để vấn đề nếu người tấn công sử dụng proxy, tham khảo:

  + http://www.freeproxylists.net/

  + https://www.hidemyass.com/en-us/proxy

  + https://www.socks-proxy.net/

- Giới hạn số lần được phép đăng nhập sai.

- Xác thực 2 yếu tố (Two-Factor Authentication)v.

- Sử dụng CAPTCHA

3. Giới thiệu CAPTCHA (Completely Automated Public Turing test to tell Computers and Humans Apart" - bài kiểm tra tính tự động để phân biệt máy tính và con người):

3.1 reCAPTCHA:

reCAPTCHA ban đầu được phát triển tại Đại học Carnegie Mellon vào đầu những năm 2000. Sau đó được Google mua lại vào năm 2009. reCAPTCHA đã trải qua nhiều phiên bản, ngày càng trở nên tinh vi hơn để đối phó với các bot tiên tiến:

- reCAPTCHA v1: Yêu cầu người dùng nhập văn bản bị méo mó (thường là từ các cuốn sách cũ đang được số hóa). Không còn được hỗ trợ.
- reCAPTCHA v2:
    - "I'm not a robot" checkbox: Người dùng chỉ cần nhấp vào một hộp kiểm. reCAPTCHA sử dụng các kỹ thuật phân tích hành vi (như cách di chuyển chuột, thời gian nhấp, địa chỉ IP, cookie...) để xác định xem người dùng có phải là bot hay không. Nếu nghi ngờ, reCAPTCHA có thể yêu cầu người dùng giải một câu đố hình ảnh (ví dụ: chọn tất cả các hình ảnh có xe buýt).
    - Invisible reCAPTCHA: chạy ngầm, không yêu cầu người dùng tương tác, trừ khi có nghi ngờ.
- reCAPTCHA v3: Hoạt động hoàn toàn dựa trên phân tích hành vi. Trả về một điểm số từ 0.0 (rất giống bot) đến 1.0 (rất giống người).

Ưu điểm:

- Phổ biến, dễ tích hợp.
- reCAPTCHA v3 cung cấp trải nghiệm người dùng tốt, không làm gián đoạn người dùng bình thường.
- Được Google duy trì và cải tiến liên tục.
- Miễn phí (với giới hạn sử dụng).

Nhược điểm:

- Lo ngại về quyền riêng tư: reCAPTCHA thu thập dữ liệu về người dùng và hành vi của họ, gây ra lo ngại về quyền riêng tư. Nhiều người dùng không thích bị Google theo dõi.
- Độ chính xác: reCAPTCHA đôi khi có thể phân loại nhầm người dùng thật là bot (false positive) hoặc bỏ qua bot (false negative).
- Trải nghiệm người dùng (với reCAPTCHA v2): Các câu đố hình ảnh có thể gây khó chịu và mất thời gian cho người dùng, đặc biệt là người khuyết tật hoặc người dùng ở các quốc gia có ít hình ảnh trong tập dữ liệu huấn luyện.
- Bot có thể vượt qua: Với sự phát triển của AI, đặc biệt là deep learning, nhiều loại bot đã có thể giải được reCAPTCHA (đặc biệt là phiên bản cũ) với độ chính xác cao.

3.2 hCaptcha:

hCaptcha là đối thủ cạnh tranh chính của reCAPTCHA, tập trung vào quyền riêng tư và khả năng tiếp cận.

Điểm nổi bật:

- hCaptcha sử dụng các câu đố hình ảnh (tương tự như reCAPTCHA v2), nhưng tập trung vào các tác vụ mà máy tính (AI) hiện tại gặp khó khăn, như phân loại hình ảnh theo các khái niệm trừu tượng, nhận dạng các vật thể bị che khuất, hoặc giải các câu đố logic.
- Dữ liệu từ hCaptcha được các công ty, tổ chức dùng để dán nhãn (label) cho các bộ dữ liệu, phục vụ machine learning
- hCaptcha có các tùy chọn thân thiện với người khuyết tật (ví dụ: câu đố âm thanh).
- hCaptcha tuyên bố tôn trọng quyền riêng tư của người dùng và không theo dõi họ trên các trang web. Họ kiếm tiền bằng cách bán dữ liệu gán nhãn hình ảnh cho các công ty AI (người dùng thực hiện các tác vụ gán nhãn hình ảnh khi giải CAPTCHA).
- Có các phiên bản tương tự reCAPTCHA, bao gồm bản ẩn.

Ưu điểm:

- Tôn trọng quyền riêng tư hơn reCAPTCHA.
- Cung cấp các tùy chọn cho người khuyết tật.
- Được thiết kế để chống lại các bot AI tiên tiến.
- Mô hình kinh doanh rõ ràng, minh bạch

Nhược điểm:

- Ít phổ biến hơn reCAPTCHA.
- Các câu đố có thể khó hơn đối với một số người dùng.

3.3 Các loại CAPTCHA:

- Nhập văn bản bị bóp méo
- Chọn/phân loại hình ảnh theo yêu cầu
- Nghe và nhập các từ/số đọc được.
- Giải các câu đố logic, toán học.
- Phân tích hành vi người dùng (chuột, bàn phím).

3.4 Một số bài viết tham khảo thêm:

- Tham khảo về quá trình phát triển của CAPTCHA: https://quantrimang.com/nguon-goc-cua-captcha-va-recaptcha-159522

- Ứng dụng của reCAPTCHA: https://quantrimang.com/bi-mat-phia-sau-chuong-trinh-mien-phi-recaptcha-bien-nguoi-dung-internet-thanh-nhan-cong-mien-phi-de-dien-tu-hoa-17-600-quyen-sach-moi-nam-160325

- Vấn đề giải mã CAPTCHA: https://kipalog.com/posts/So-sanh-10-dich-vu-giai-ma-Captcha-tot-nhat-tren-the-gioi

Hết